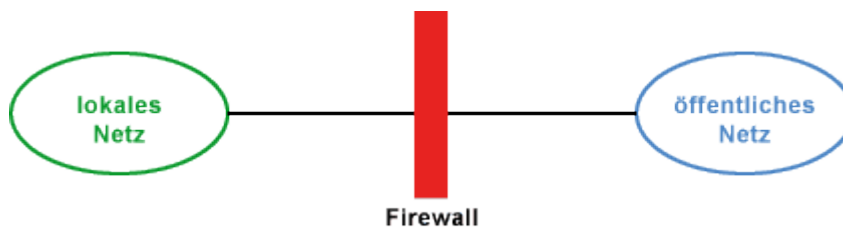


Firewall



Eine Firewall ist eine Schutzmaßnahme gegen fremde und unberechtigte Verbindungsversuche aus dem öffentlichen (Internet) ins lokale Netzwerk. Mit einer Firewall lässt sich der kommende und gehende Datenverkehr kontrollieren, protokollieren, sperren und freigeben. Dabei ist die Firewall genau zwischen dem öffentlichen und dem lokalen Netzwerk platziert. Meist ist die Firewall Teil eines Routers. Sie kann aber auch als externe Komponente einem Router vor- oder nachgeschaltet sein.

Firewall als Sicherheitsstrategie

Eine Firewall ist keine Blackbox, die Sicherheit für das lokale Netzwerk vor dem öffentlichen Netzwerk vorgaukelt. Eine Firewall ist eine technische Einrichtung, die eine Sicherheitsstrategie umsetzt, um unerwünschte, unsichere und schädigende Verbindungen zu verhindern. Ohne ständige Überwachung und Pflege bleibt nach einiger Zeit keine Schutzwirkung übrig.

Vor dem Einsatz einer Firewall ist die Akzeptanz und aktive Mitarbeit aller Beteiligten innerhalb eines lokalen Netzwerks zu gewährleisten, damit die Firewall effektiv funktionieren kann.

Am Anfang steht die Entscheidung zur Grundhaltung gegenüber Datenverbindungen. Die Firewall kann zunächst alle Verbindungen erlauben und nur bekannte und gefährliche Datenverbindungen unterbinden. Oder sie sperrt alles und alle erwünschten Datenverbindungen müssen explizit freigegeben werden.

Firewall-Strategie: Alles sperren

Alles ist gesperrt. Bekannte sichere und erwünschte Vorgänge werden freigegeben.

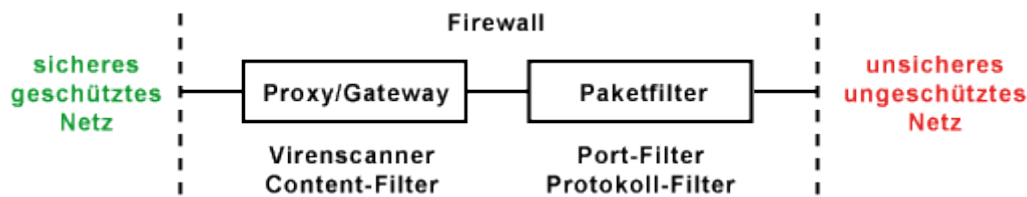
Diese Variante ist sehr sicher. Allerdings erfordert sie eine aufwendige Konfiguration der Firewall.

Firewall-Strategie: Alles freigeben

Alles ist freigegeben. Bekannte unsichere und unerwünschte Vorgänge werden gesperrt.

Diese Variante ist relativ komfortabel. Bei der Einführung ist mit keinerlei Problemen zu rechnen. Allerdings ist sie nur so sicher, wie Gefahren und Sicherheitslöcher bekannt sind und gesperrt werden.

Elemente einer Firewall



Grundsätzlich gibt es zwei verschiedene Ansätze für ein Firewall-Konzept:

- passiver Paketfilter mit Port- und Protokoll-Filter
- aktives Gateway (Proxy) mit Virens Scanner und Content-Filter

Ein Paketfilter (TCP/IP) kontrolliert die Quell- und Ziel-IP sowie die dazugehörigen Portnummern (TCP). Neben der Filterfunktion ist die Protokollierung abgelehnter Pakete für spätere Analysen wichtig.

Das Gateway ist ein Proxy, der die Datenpakete der Internet-Dienste (HTTP, FTP, ...) zwischenspeichert. Dadurch lässt sich eine inhaltsbezogene Filterung der Daten vornehmen. Für ein LAN mit viel E-Mail-Verkehr ist ein Virencheck für E-Mails besonders empfehlenswert.

Einen optimalen Schutz erreicht man durch eine Kombination aus Paketfilter und Proxy. Vorzugsweise sollte der Paketfilter dem Proxy vorgeschaltet sein, um unnötigen Datenverkehr über den Proxy zu vermeiden. Inhaltsbezogene Filterungen benötigen deutlich mehr Rechenleistung. Der Proxy sollte deshalb mit viel Rechenleistung und Arbeitsspeicher ausgestattet sein.

Eine Firewall kann ein einzelner Computer oder eine Kombination aus Proxy und einem Router sein. Praktikabel ist es, wenn der Paketfilter ein Router mit Firewall-Funktionen ist.

Hauptproblem beim Einrichten einer Firewall ist das Überprüfen der Filterregeln und Beschränkungen. Nur wenige Firewall-Produkte bieten diese Möglichkeit. Sich auf die einwandfreie Funktion der Firewall zu verlassen wäre fatal. Entweder man beauftragt eine externe Firma, die Firewall zu testen oder man beschafft sich einschlägige Software-Tools und testet die Firewall selber. Aber über einen anderen Internet-Zugang, nicht über das eigene lokale Netz!

- [Was ist ein offener Port? \(TCP- und UDP-Ports\)](#)

Angriffsszenarien, die eine IPv6-Firewall abwehren muss

Eine Firewall für IPv4 filtert keinen IPv6-Verkehr. Und IPv6 ist nicht einfach nur ein IPv4 mit anderen Adressen. Die Erfahrungen aus der IPv4-Welt lassen sich nur bedingt auf IPv6 übertragen. Der Schutz eines LANs durch eine Firewall bedarf für IPv6 völlig neuer Regeln, die bei IPv4 bisher nicht notwendig waren.

- Umgehen der Filterregeln durch den kreativen Einsatz von Extension Header.

- IPv6-Datagramme mit vorgetäuschter Absender-Adresse aus dem internen Netz.
- Beliebige ICMPv6-Pakete
- Fluten der NDP-Table
- Überlasten der Firewall per TCP-Flooding

Es muss nicht immer zwangsläufig das Umgehen der Firewall sein. Einem Angreifer kann es schon genügen, wenn die Firewall überlastet wird und somit die Verbindung zum Internet gestört ist.

Sicherheitsvorkehrungen?

Keine Sicherheitsvorkehrungen oder Sicherheitsmechanismen zu verwenden ist fahrlässig. Allerdings sollte man schon genau hinschauen, was einem so als Sicherheitsfunktion angeboten wird.

Ein **MAC-Filter**, wie er in WLAN-Access-Points angeboten wird, ist als Sicherheitsfunktion bedingt tauglich. Zum einen ist der Verwaltungsaufwand groß und zweitens für einen Hacker kein wirkliches Hindernis. Jeder Netzwerk-Adapter kann mit einer anderen MAC-Adresse versehen werden.

NAT wird besonders in Produkt-nahen Beschreibungen als Sicherheitsmerkmal beschrieben. Hinter NAT steckt ein Mechanismus, der als Nebenprodukt verhindert, dass Stationen hinter dem NAT-Router von außerhalb direkt ansprechbar sind (bei IPv4). Von außen initiierte Verbindungsversuche werden verworfen und bekommen keinen Zugang zum lokalen Netzwerk.

NAT als Sicherheitsmerkmal zu bezeichnen ist irreführend, weil es nicht die Aufgabe von NAT ist, die Sicherheit zu erhöhen.

Ein weiterer gut gemeinter Ratschlag ist das **Blockieren von Ports**. Dadurch soll verhindert werden, dass über nicht blockierte Ports irgendwelche Dienste angesprochen werden können. Allerdings erreicht man dadurch nicht mehr Sicherheit. Protokolle sind nicht an bestimmte Ports gebunden. Sie können irgendwelche Ports verwenden. Ziel sollte es sein, alle nicht in Gebrauch befindlichen Dienste abzuschalten. Denn dann braucht man sich um offene Ports keine Sorgen machen. Ports sperrt nur derjenige, der seine Server- und Netzwerk-Dienste nicht im Griff hat.

Trotz aller Sicherheitsmaßnahmen ist die beste Firewall die Isolation. Computer mit sensiblen oder datenschutzrechtlichen Daten sollten autark und vom Netzwerk getrennt laufen.

SPI - Stateful Packet Inspection

SPI ist ein Firewall-Leistungsmerkmal. Dieses Verfahren entscheidet anhand mehreren Kriterien, ob ein eingehendes Datenpaket weitergeleitet oder verworfen wird. Z. B. wird der Zielport als Kriterium verwendet. Ist in der Firewall für diesen Port kein Server

angegeben, werden die Datenpakete für diesen Port verworfen. SPI überprüft auch, ob eingehende Datenpakete zu zuvor gesendeten Datenpaketen in Beziehung stehen. Also zu einer Sitzung gehören, die durch das sichere lokale Netzwerk ausgelöst wurden. Datenpakete, die sehr häufig eintreffen werden identifiziert. Liegt der Verdacht nahe, dass es sich um eine DoS-Attacke (Denial-of-Service) handelt werden diese Datenpakete automatisch verworfen.

- [SPI - Stateful Packet Inspection](#)

Next Generation Firewall

Die Bezeichnung "Next Generation Firewall" wurde von Gartner Research (Marktforschungsinstitut im Bereich IT) definiert. Diese Firewall der nächsten Generation kann im Datenstrom Anwendungen und Benutzer erkennen. Dazu gehört ein integriertes Intrusion Prevention System (IPS), die Identifikation von Anwendungen und Protokollen unabhängig vom genutzten Port und die Berücksichtigung externer Datenquellen, wie zum Beispiel Verzeichnisdienste mit Benutzerdaten.

Next Generation Firewalls gehen also über die üblichen Fähigkeiten einer Firewall, wie Paketfilter, Network Address Translation (NAT) und Stateful Inspection hinausgeht.

Insbesondere die Benutzer- und Anwendungserkennung ist für die zukünftige Sicherheit von Netzwerk extrem wichtig. Seit sich HTTP als Universalprotokoll entwickelt hat, müssen nicht mehr nur ein Browser und Webserver die Endpunkte einer HTTP-Verbindung sein. Grundsätzlich kann man mit HTTP alles transportieren. Aus Sicherheitsgründen darf man HTTP nach außen hin nicht mehr generell freigeben. Hier setzt die Anwendungserkennung an, die versucht zu erkennen, was das System gerade überträgt. Die Anwendungserkennung übernimmt die Fähigkeiten eines Proxys bzw. Content-Filters. Aber sie muss weit mehr als das leisten. Um Anwendungen zu erkennen, bedarf es einen Abgleich mit Erkennungsmustern, ähnlich wie bei einem Virenschanner. Dabei ist es notwendig, dass diese Muster regelmäßig aktualisiert werden.

Typischerweise versucht man Google, Facebook, Youtube, Chats und Peer-to-Peer-Anwendungen zu erkennen. Wobei die meisten Anwendungen eher privater Nutzung zuzuordnen sind. Hierbei besteht der Irrweg darin, die Benutzer zu kontrollieren, anstatt Sicherheitslücken zu schließen. Sicherlich sinnvoll, wenn man bedenkt, dass der Mensch das größte Sicherheitsrisiko darstellt. Viel wichtiger wäre jedoch, dass die Firewall Anwendungen erkennt, vor denen das Unternehmensnetz tatsächlich geschützt werden muss.

Eine Firewall sollte im Optimalfall auch der VPN-Endpunkt sein. Damit können die Firewall-Regeln auch für die VPN-Daten gelten.

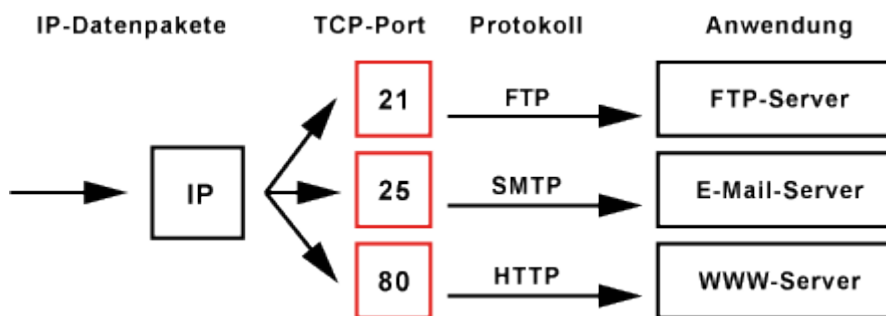
Zero Trust

Zero Trust ist ein Sicherheitskonzept, bei dem generell jedem Netzwerkverkehr, unabhängig von seiner Herkunft, misstraut wird. Teil des Konzepts ist, dass jeder Zugriff einer Zugangskontrolle und jede Verbindung einer Verschlüsselung unterliegt.

- [Zero Trust](#)

TCP- und UDP-Ports

TCP- und UDP-Ports sind eine Software-Abstraktion, um parallele Kommunikationsverbindungen einer oder mehreren Anwendungen voneinander unterscheiden zu können. Ähnlich wie IP-Adressen zur Adressierung von Rechnern in Netzwerken dienen, adressieren Ports spezifische Anwendungen und ihre Verbindungen, die auf einem Rechner laufen.



Datenpakete, die über IP ihr Ziel erreichen, werden von TCP zusammengesetzt und an eine Anwendung übergeben. Da mehrere Anwendungen zugleich TCP-Verbindungen aufbauen können, muss eine Zuordnung zwischen Datenpaket und Anwendung erfolgen. Zu diesem Zweck wird eine Kennung zwischen Daten und Anwendung definiert, die als Port bezeichnet wird. Es handelt sich dabei um eine fortlaufende Nummer zwischen 0 bis 65.535. TCP-Pakete sind mit diesen Port-Nummern, jeweils eine für Sender und Empfänger, versehen. Mit den Ports ist es möglich, dass die Datenpakete mehrerer Verbindungen dem richtigen Datenstrom zugeordnet werden können.

Übersicht: Ports

Die Port-Nummern, die für TCP und UDP gleichzeitig gelten, werden von der IANA (Internet Assigned Numbers Authority) bzw. ICANN (Internet Corporation for Assigned Names and Numbers) verwaltet und vergeben.

Well Known Ports (0 - 1.023): Diese Port-Nummern sind einem Dienst oder einem Anwendungsprotokoll fest zugeordnet. Jeder Dienst hört standardmäßig auf einen solchen Port. Man bezeichnet sie auch als Standard- oder Default-Ports (Destination-

Port). Um Fehler und die damit einhergehende Fehlersuche zu vermeiden, sollte diese Zuordnung nicht verändert werden.

Registered Ports (1.024 - 49.151): Diese Port-Nummern sind zur Registrierung freigegeben. Im Prinzip kann sich jeder einen Port bei der IANA/ICANN für seine Anwendung reservieren, wenn er es begründen kann. Es ist durchaus möglich, dass diese Ports mehrfach belegt sind.

Dynamically Allocated Ports (49.152 - 65.535): Die darüberliegenden Port-Nummern, ab 49.152, können frei belegt werden bzw. werden dynamisch zugewiesen. Typischerweise nutzen Client diese Ports für ausgehende Verbindungen (Source-Port).

Wenn Anwendungen zu einem Server Kontakt aufnehmen wollen, dann vergibt TCP bzw. UDP den Standard-Port für den Empfänger-Port und vergibt einen freien Port ab 49.152 für den Sender-Port. Wenn der Server die Daten erhalten hat und eine Antwort zurückschickt, dann werden die Port-Nummern vertauscht. Damit wird sichergestellt, dass die Daten nicht an eine falsche Anwendung übergeben werden.

Beispiele für Standard-Ports (TCP)

Port-Nummer	Protokoll	Anwendung
21	FTP	Dateitransfer (FTP-Server)
23	Telnet	Konsole (Server)
25	SMTP	Postausgang (SMTP-Server)
80	HTTP	World Wide Web (Webserver)
110	POP	Posteingang (POP-Server)
119	NNTP	Usenet (News-Server)

- [TCP- und UDP-Ports \(Übersicht\)](#)

Beispiele für Standard-Ports (UDP)

Port-Nummer	Protokoll	Anwendung
53	DNS	Domain Name Server
69	TFTP	Trivial File Transfer Protocol
137	NetBIOS-ns	NetBIOS Nameserver
138	NetBIOS-DGM	NetBIOS-Datagramm-Dienst
161	SNMP	Simple Network Management Protocol

- [TCP- und UDP-Ports \(Übersicht\)](#)

Port-Zustände

Ports können mehrere Zustände aufweisen. Der Zustand eines Ports definiert, ob eine Kommunikation über diesen Port zu einer dahinterliegenden Anwendung möglich ist, oder nicht. Vereinfacht gesehen gibt es drei Zustände.

- Open / Offen
- Closed / Geschlossen
- Filtered / Gefiltert (Blocked / Geblockt)

In der Regel reicht es aus, wenn man alle Ports pauschal in diese zwei (offen, geschlossen) oder auch drei Zustände einteilt (offen, geschlossen, gefiltert). Es gibt allerdings eine Betrachtungsweise auf Ports, die mehr Zustände zulässt. So kennt der Port-Scanner NMAP insgesamt sechs Port-Zustände, die wir hier aber nicht weiter betrachten.

- [NMAP - Network Mapper](#)
- [Port-Scanning \(Grundlagen\)](#)
- [Port-Scanning mit NMAP](#)

Open / Offen

Der Zustand "Open" oder "Offen" ist dann gegeben, wenn auf einem spezifischen Port eine Anwendung lauscht. Mit "Offen" ist gemeint, dass man zu einer Anwendung über diesen Port eine Verbindung aufbauen kann.

Closed / Geschlossen

Der Zustand "Closed" oder "Geschlossen" ist der Standardzustand eines Ports. Er ist dann gegeben, wenn auf einem spezifischen Port keine Anwendung lauscht. Der Host wird eine Verbindung zu diesem Port aktiv ablehnen. Mit "Geschlossen" ist gemeint, dass es keine Anwendung gibt, zu der man eine Verbindung über diesen Port aufbauen kann.

Zumindest gibt es auf TCP/UDP-Ebene keine Verbindungsmöglichkeit. Denn der Zustand "Geschlossen" kann auch dann gelten, wenn das kontaktierte System durch eine Firewall geschützt ist und die Verbindungsversuche auf einem bestimmten Port aktiv ablehnt. Das bedeutet aber auch, dass zu der dahinterliegenden Anwendung keine Verbindung aufgebaut werden kann.

Filtered / Gefiltert (Blocked / Geblockt)

Der Zustand "Filtered" oder "Gefiltert" ist dann gegeben, wenn der kontaktierte Port durch eine Firewall geschützt ist und auf Verbindungsversuche nicht antwortet. Das heißt, die Verbindung wird weder bestätigt (Offen), noch abgelehnt (Geschlossen). Man muss also annehmen, dass der Verbindungsversuch aktiv blockiert wird. Das gilt aber nur dann, wenn der Host generell online ist, also auf mindestens einem anderen Port eine Verbindung zulässt.

Der Zustand "Gefiltert" drückt aus, dass der Port nicht erreicht werden kann, weil er zum Beispiel durch eine Firewall-Regel blockiert wird. Dieser Zustand kann aber auch dadurch entstehen, dass der kontaktierte Host gar nicht erreichbar ist.

Was ist ein offener oder geschlossener Port?

Was bedeutet es, wenn von einem "offenen Port" die Rede ist? Ein Port gilt dann als offen, wenn eine Anwendung an einem Port Datenpakete entgegennimmt, die an diesen Port geschickt werden, ohne dass die Anwendung dieses Datenpaket angefordert hat. Ein Port wird dann "geöffnet", wenn eine Anwendung gestartet wird, die an diesem Port "lauscht".

Ein Port gilt als "geschlossen", wenn keine Anwendung an diesem Port "lauscht". Man kann einen Port also nur dadurch schließen, in dem man das betreffende Programm beendet. Werden Datenpakete dann an diesen Port geschickt, werden sie zurückgewiesen.

Wie kann man sich vor "offenen Ports" schützen?

"Offene Ports" sind kein Problem. Sie sind Bestandteil einer verbindungsorientierten Kommunikation in einem Netzwerk. "Offene Ports" sind erst dann ein Problem, wenn der Anwender von dem offenen Port, also vom Starten einer Anwendung, die auf einen bestimmten Port hört, nichts mitbekommt. Zum Beispiel, wenn die Anwendung im Hintergrund läuft. Das können reguläre Systemdienste, aber auch Schadsoftware sein. Ein unerwünschter offener Port wäre dann eine Sicherheitslücke.

Um zu verhindern, dass ein Port unberechtigtweise geöffnet wird, wird oft eine Firewall

oder ein Portfilter vorgeschaltet, der Verbindungen von außen auf von innen unberechtigt geöffnete Ports verhindert.

Als Anwender kann man sich vor dem Öffnen eines Ports durch eine unberechtigte Anwendung dadurch schützen, dass man eine Desktop-Firewall installiert, die vor Verbindungsversuchen von innen nach außen warnt und explizit um Erlaubnis fragt. Auf diese Weise kann man verhindern, dass Anwendungsprogramme nicht zum Einfallstor werden.

Portknocking

Portknocking ist die Idee, auf der einen Seite Dienste vor potenziellen Angreifern zu verstecken (Port-Zustand "Geschlossen") und auf der anderen Seite trotzdem Verbindungen herstellen zu können (Port-Zustand "Offen").

Dazu befindet sich ein bestimmter Port im Grundzustand "Geschlossen". Um trotzdem eine Verbindung auf diesen Port herstellen zu können, muss der entfernte Host eine Klopfsequenz generieren, die aus einer Reihe von Verbindungsversuchen auf gefilterte Ports besteht. Diese Verbindungsversuche werden von einer Firewall verworfen und zusätzlich aufgezeichnet. Ein Portknocking-Daemon überwacht die Firewall-Protokollierung. Erkennt er eine Klopfsequenz, ändert er die Firewall-Regeln, um einen oder mehrere Ports zu öffnen. Nachdem die gewünschten Ports offen sind, kann der entfernte Host eine reguläre Verbindung aufbauen. Mit einer weiteren Klopfsequenz kann der entfernte Host den Port wieder schließen lassen.

Standard-Ports aus Sicherheitsgründen ändern?

Standard-Ports, zwischen 0 und 1.023 haben den Nachteil, dass die Zuordnung zwischen Port-Nummer und Anwendung bekannt ist. Was Absicht und auch gut ist. Ein Webbrowser weiß, dass ein Webserver auf Port 80 zu erreichen ist. Somit muss sich der Anwender auf dieser Ebene um nichts kümmern.

Es gibt aber auch Anwendungen, die den Nutzer Authentifizieren müssen. Zum Beispiel bei SSH zur Remote-Steuerung oder Fernwartung von Computern. Ein Angreifer macht sich mit dem Wissen, dass der SSH-Server auf Port 22 hört, zu Nutze, um seine Angriffe auf diesen Port gegen die Authentifizierung laufen zu lassen. Sein Ziel wäre, die Kontrolle über den Server per SSH zu übernehmen.

Wenn ein Angreifer einen Server unter seine Kontrolle bringen will, dann wird er also versuchen, den SSH-Server anzugreifen. Um das zu verhindern, gehen manche Systemadministratoren dazu über, Dienste, wie zum Beispiel SSH, auf andere, als den Standard-Port hören zu lassen. Damit erschweren Sie es Angreifern eventuelle Schwachstellen allzu leicht zu finden. Denn wenn ein Angreifer einen SSH-Server nur auf Port 22 vermutet, der richtige Port aber woanders liegt, dann lässt sich auf diese Weise ein Angriff vielleicht verhindern.

Das ist allerdings nur bedingt richtig. Korrekt ist, dass man mit dem Verschleiern von Ports nur automatisierte Port-Scans und unerfahrende Script-Kiddies davon abhalten

kann, angreifbare Dienste zu finden. Den erfahrenen Angreifer, der wirklich in ein System eindringen will, wird man so nicht davon abhalten, sondern seine Bemühungen höchstens etwas verzögern.

Dazu muss der Angreifer alle 65.536 Ports eines Systems scannen und die tatsächlich dahinter lauschenden Anwendungen prüfen. Das ist natürlich aufwendig, aber nicht unvorstellbar. Mit den richtigen Tools und etwas Zeit bekommt man schnell heraus, wenn ein SSH-Server auf einem anderen Port hört als den Standard-Port.

Standard-Ports zu ändern hat für normale Nutzer Nachteile. Die müssen wissen, auf welchem Port welcher Dienst läuft. Da typische Clients von Standard-Ports ausgehen, muss bei der Adressierung immer der geänderte Port bekannt gegeben werden. Das ist einerseits unbequem. Andererseits wird es schnell kompliziert, wenn verschiedene Systeme für den gleichen Dienst unterschiedliche Port-Nummern aufweisen. Aus diesem Grund definiert man dann die Port-Vergabe wieder zentral, was dann allerdings den Nachteil hat, dass man es einem Angreifer dann wieder leichter macht.

Eine grundsätzliche Empfehlung kann man nicht so einfach geben. Das Anwendungen auf Standard-Ports leichter anzugreifen sind, ist klar. Allerdings muss man die Port-Änderung gut überlegen. Wo es sinnvoll ist, ist bei Systemen, die über das Internet erreichbar sind. Um die Last auf die Systeme zu begrenzen, macht es Sinn Standard-Ports für SSH und andere Remote-Zugängen zu ändern. Das verhindert, dass systematische Port-Scans auf einen offenen SSH-Port treffen.

Andererseits muss man die aufgestellte Sicherheits-Policy anzweifeln, wenn Standard-Ports geändert werden müssen, weil ein Sicherheitsrisiko vorliegt. Wenn das so sein sollte, dann ist der eigentlich richtige Weg, Verbindungen von entfernten Rechnern auf diesen Port gar nicht zu erlauben. Zum Beispiel sollte der SSH-Server nur lokal, aber nicht aus dem öffentlichen Netz erreichbar sein.

Wenn es sich nicht vermeiden lässt, dann muss man sich darüber im Klaren sein, dass auf so einem Server keine kritischen Daten liegen und Anwendungen laufen dürfen.

Denn ein solches System ist grundsätzlich angreifbar. In so einem Fall sind dann zusätzliche Sicherheitsmaßnahmen notwendig. Das Ändern des Standard-Ports ist dann nur eine Option.

TCP- und UDP-Ports (Übersicht)

<https://www.elektronik-kompodium.de/sites/net/2911021.htm>

Quellen: <https://www.elektronik-kompodium.de/>